

## SECCIÓN 2.5



# IOC, IOA y evidencia de seguridad

### Temas de esta sección:

- Qué es un IOC (Indicador de Compromiso) y ejemplos
- Limitaciones de los IOC: por qué no son suficientes solos
- Qué es un IOA (Indicador de Ataque) y comportamiento
- Diferencia práctica entre IOC e IOA
- Qué es evidencia: dato, indicador, evidencia, conclusión
- Cómo correlacionar evidencia para análisis más sólido
- Errores comunes al interpretar indicadores



En un SOC, muchas alertas incluyen indicadores. Pero no todos tienen el mismo valor ni la misma estabilidad.

IOC — Indicador de Compromiso

Evidencia específica asociada a una amenaza o compromiso conocido.

Pregunta: ¿Qué indicador específico se observó?

- Hash de malware
- Dirección IP maliciosa
- Dominio sospechoso
- URL de phishing
- Clave de registro

⚠ Limitación: El atacante puede cambiar el hash, el dominio o la IP fácilmente.

IOA — Indicador de Ataque

Comportamiento o patrón que puede indicar una técnica de ataque.

Pregunta: ¿Qué comportamiento se observó?

- PowerShell ejecutado por Word
- Conexiones periódicas (beaconing)
- Eliminación de shadow copies
- Compresión antes de transferencia externa
- Creación de persistencia

⚠ Limitación: Puede generar más falsos positivos si falta contexto.

## 2.5 | Ejemplo IOA: la secuencia importa más que el indicador



### Alerta EDR — secuencia observada:

```
WINWORD.EXE → powershell.exe
```

```
powershell -nop -w hidden -enc <b64>
```

```
PowerShell → conexión HTTPS externa
```

```
Descarga de archivo ejecutable
```

```
Hash: desconocido · Dominio: desconocido
```

### ¿Por qué es sospechoso aunque no haya IOC conocido?

- ▶ Word no debería ejecutar PowerShell en uso normal.
- ▶ -nop -w hidden -enc → parámetros de evasión.
- ▶ Hay comunicación externa no esperada.
- ▶ Hay descarga de un ejecutable.
- ▶ El usuario no tiene rol técnico.
- ▶ La secuencia es compatible con ejecución inicial maliciosa.

*Este es un IOA: lo importante no es un indicador puntual, sino la cadena de comportamiento.*

# 2.5 | Dato, indicador, evidencia y conclusión



En un análisis SOC es crítico no mezclar niveles. Saltar del dato a la conclusión es un error muy frecuente:

|                 |                                                          |                                                                                                                   |
|-----------------|----------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|
| 1<br>DATO       | Un registro o valor observado sin interpretación.        | <i>Ej: powershell.exe se ejecutó a las 10:34.</i>                                                                 |
| ↓               |                                                          |                                                                                                                   |
| 2<br>INDICADOR  | Un dato que puede tener relevancia de seguridad.         | <i>Ej: powershell.exe se ejecutó con -enc (comando codificado).</i>                                               |
| ↓               |                                                          |                                                                                                                   |
| 3<br>EVIDENCIA  | Un dato o conjunto de datos que sostiene una hipótesis.  | <i>Ej: Word ejecutó PowerShell con parámetros codificados, luego hubo conexión externa y descarga de archivo.</i> |
| ↓               |                                                          |                                                                                                                   |
| 4<br>CONCLUSIÓN | La interpretación basada en evidencia, no en suposición. | <i>Ej: La actividad es sospechosa y compatible con ejecución inicial maliciosa. Se recomienda escalamiento.</i>   |

Error crítico: saltar del DATO a la CONCLUSIÓN sin pasar por INDICADOR y EVIDENCIA.

## 2.5 | Errores comunes al interpretar indicadores



Los errores más frecuentes al trabajar con IOC e IOA:

### ✗ Creer que un IOC siempre confirma compromiso

✓ Un dominio de mala reputación puede ser hosting compartido o CDN. Validá el contexto siempre.

### ✗ Cerrar un caso porque no hay IOC conocido

✓ Si el comportamiento (IOA) es sospechoso, la ausencia de IOC no cierra el caso.

### ✗ Depender solo de reputación

✓ La reputación responde 'qué se sabe del indicador'. La investigación responde 'qué pasó acá'.

### ✗ Ignorar comportamiento sospechoso

✓ Un dominio desconocido + PowerShell desde Word + descarga = IOA fuerte. No importa si la reputación es neutra.

### ✗ No documentar la fuente del indicador

✓ ¿El hash vino del EDR? ¿La IP del SIEM? ¿El dominio de threat intel? Esto afecta la confianza.

### ✗ Escalar solo con 'apareció un indicador'

✓ Escalar requiere contexto: qué pasó, qué evidencia respalda, por qué es relevante.